

Implement Security Monitoring and Incident Response

A basic DeRexi monitoring use case plus one documented incident-response scenario

ASSIGNMENT OBJECTIVE

Show security monitoring knowledge through one monitoring use case with detection rules, alert prioritization, and response procedures; then document one incident-response scenario with classification, response steps, and lessons learned.

1. Basic security monitoring use case

Use case: Detect suspicious command execution and credential activity on a DeRexi employee endpoint. The use case reuses the APT38 / BeagleBoyz educational scenario already developed for the banking context, but turns it into explicit monitoring logic.

Log source / event	Detection rule	Initial priority	Why it matters
PowerShell Operational / 4104	Alert when script-block logging shows suspicious encoded commands, download/execution behavior, or unexpected PowerShell from a user workstation.	P2	Could indicate attacker-controlled execution.
Windows System / 7045	Alert on creation of a previously unseen Windows service on an employee endpoint.	P2	Can indicate persistence.
Windows Security / 4625	Alert when 5+ failed logons occur within 10 minutes for one account/source.	P2	Could indicate brute force or credential misuse.
Correlation rule	Raise to P1 when two or more detections occur on the same endpoint/account within 30 minutes, especially on a privileged account or critical system.	P1	Multiple behaviors increase confidence that the activity is malicious.

2. Alert prioritization process

Priority	Criteria	Expected action
P1 - Critical	Correlated malicious behaviors, privileged account, critical server, or evidence of active compromise	Immediate analyst triage, isolate if confirmed, escalate incident response.
P2 - High	Single high-confidence detection such as service creation or repeated authentication failure	Review within 15 minutes; gather endpoint, account, and network context.
P3 - Medium/Low	Single low-confidence anomaly without corroborating evidence	Queue for review; enrich with user/device baseline and threat intelligence.

3. Response procedure for the monitoring use case

- Validate the alert by checking the user, endpoint, timestamp, command/service details, and surrounding authentication activity.
- Contain confirmed suspicious activity by isolating the endpoint, disabling or locking affected accounts, and revoking active sessions.
- Preserve PowerShell, Security, System, application, and network logs before remediation changes erase evidence.
- Check whether DeRexi policy content, administrative configuration, or client-access paths were touched; compare against trusted versions and audit history.
- Escalate P1 events to incident response, leadership, legal/compliance, and banking-client communication procedures when client impact is possible.

FUNCTIONALITY EVIDENCE

The rule set below is a documented monitoring configuration and educational validation model. The event sequence on page 2 demonstrates how the rules would fire and be prioritized. It is intentionally labeled simulated rather than presented as live production telemetry.

4. Incident-response scenario - APT38 / BeagleBoyz

Classification: HIGH severity | **Categories:** phishing/malware, unauthorized access, credential activity, persistence, discovery, and potential supply-chain exposure. **Scenario status:** fictional / educational.

Time	Simulated event	Rule / priority	Response
08:47	Unusual PowerShell executes after a malicious policy-review attachment is opened.	4104 / P2	Begin triage; collect process and script context.
09:03	Previously unseen Windows service is created.	7045 / P2 -> correlated P1	Escalate; prepare endpoint isolation.
09:18	Repeated authentication attempts target additional internal accounts.	4625 / P2 -> P1	Disable affected credentials; revoke sessions.
09:31	Endpoint enumerates directories and network shares.	Behavioral context / P1	Confirm active compromise; restrict access paths.
10:02	Temporary artifacts disappear and timestamps appear abnormal.	Defense-evasion context / P1	Preserve centralized evidence; expand scope.
10:09	Correlated alerts satisfy P1 incident threshold.	Correlation / P1	Declare incident; activate response team.
10:16	Endpoint isolated; accounts disabled; client-facing paths restricted.	Containment	Move into eradication, recovery, and validation.

5. Incident response steps

1 IDENTIFY Correlate PowerShell, service creation, authentication, and discovery alerts.	2 CONTAIN Isolate endpoint; disable accounts; revoke sessions; restrict client-facing access.
3 PRESERVE Centralize and retain endpoint, identity, application, and network logs.	4 ERADICATE Remove malicious persistence/tools; patch/harden affected systems; rotate credentials.
5 RECOVER Restore trusted configurations and policy versions; validate user and client access.	6 MONITOR Watch for recurring authentication failures, PowerShell, new services, share discovery, and integrity changes.

6. Lessons learned

- Correlation matters: one event may be ambiguous, but PowerShell + service creation + repeated logon failures creates a much stronger signal.
- Centralized logs protect the investigation trail when an attacker deletes local artifacts or changes timestamps.
- Phishing-resistant MFA, least privilege, segmentation, and separation of administrative identities reduce the blast radius of credential compromise.
- For DeRexi, policy integrity must be monitored like a security control because employees rely on the platform for trusted incident guidance.
- A predefined client-communication and escalation process is necessary because a DeRexi compromise could create downstream banking risk.

ASSIGNMENT CRITERIA CHECK

1 monitoring use case with detection rules ✓ | Alert prioritization process ✓ | Response procedure ✓ | 1 incident-response scenario with classification, response steps, and lessons learned ✓ | Simulated evidence clearly labeled ✓

SOURCE BASIS DeRexi APT38 / BeagleBoyz Incident MITRE Report; DeRexi Vulnerability Assessment Report; DeRexi Access Control Measures Report.